

# DeBug : A Decentralised Bug-Bounty Platform

Inhouse Project  
Review – I

Project Mentor : **Ms. Geocey Shejy**



**Group Number : 19**

**Group Members :**

**Rohit Shahi [D17C/58]**

**Gopal Vanjarani [D17C/66]**

**Gaurav Mahadeshwar [D17C/43]**

**Umesh Tolani [D17C/64]**

# Content

- I. Introduction to Project**
- II. Lacuna in the existing systems**
- III. Problem Definition**
- IV. Literature Survey**
- V. Methodology employed**
- VI. Hardware, Software, tools and the constraints**
- VII. Block Diagram**
- VIII. Modular Diagram**
- IX. Next Work Plan**
- X. Conclusion**
- XI. References**

# Introduction to Project

DeBug is an innovative decentralized bug-bounty platform that aims to build a transparent, trustworthy, and scalable ecosystem for security vulnerability reporting and reward distribution. By leveraging blockchain technology, it eliminates custodial risks, opaque payouts, and privacy concerns found in traditional platforms. DeBug follows a hybrid model—its on-chain Layer-2 components manage escrow, payouts, and dispute resolution, while off-chain web services handle authentication, encrypted submissions, notifications, and researcher reputation. This integration ensures verifiable payouts, researcher anonymity, and reputation portability across platforms. Designed for security researchers, software organizations, startups, and open-source communities, DeBug creates a fair, secure, and efficient environment for ethical vulnerability disclosure and collaboration.

# Lacuna in the existing system

## **Centralization & Trust**

Existing bug-bounty platforms operate under centralized control, leading to disputes, delayed disclosures, and lack of transparency. This dependency on intermediaries reduces trust among researchers and organizations.

## **Incentive Misalignment**

Many platforms offer low or capped rewards, discouraging ethical hackers. The imbalance between effort and payout makes vulnerability disclosure less appealing compared to exploitation.

## **Payment Friction**

Traditional fiat-based payments introduce delays, high transaction fees, and limited crypto support, making global participation slow and inconvenient.

# Lacuna in the existing system

## **Uncertainty & Delays**

Bug acknowledgments and payouts are often unpredictable due to opaque triage processes and inconsistent timelines, reducing researcher motivation.

## **Privacy Limitations**

Web2-based platforms require KYC or real IDs, preventing anonymous or encrypted submissions. This compromises researcher privacy and restricts participation from global contributors.

## **Lack of Dispute Transparency**

Dispute resolution in existing platforms is often handled privately by centralized admins, offering little visibility into decisions. This opaque process can lead to biased judgments and reduced trust among participants.

# Problem Definition

Traditional bug bounty platforms rely heavily on centralized trust and manual policies, which often lead to inefficiencies and researcher dissatisfaction. Verification of submitted reports is typically slow and lacks transparency, resulting in delays and friction in reward distribution. Moreover, arbitrary reward caps frequently undervalue critical exploits, discouraging skilled researchers from active participation. Disputes, inconsistencies in payout decisions, and custodial risks further erode researcher confidence. These limitations not only weaken trust between organizations and security researchers but also increase the risk of undisclosed vulnerabilities remaining unpatched, leaving systems exposed to potential threats.

# Literature Survey

| Publication Year | Title of Paper                                                    | Abstract                                                                                                                                     | Research Gap                                                                                                           | Conclusion                                                                                                 |
|------------------|-------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| 2021             | Bountychain: A Decentralized Bug Bounty Platform (Hoffman et al.) | Proposes a blockchain-based bug bounty platform using Ethereum smart contracts and IPFS to automate payouts and store immutable records.     | Limited by Ethereum gas fees and on-chain storage constraints for large reports.                                       | Demonstrates feasibility of decentralized bug bounty programs; recommends optimizing cost and scalability. |
| 2020             | VeriOSS: Using the Blockchain to Foster Bug Bounty Programs       | Introduces VeriOSS, a blockchain-based platform ensuring fairness and trust in bug disclosure via economic incentives and formal guarantees. | Limited to local software copies; lacks exploit support and robust identity verification; assumes single participants. | Promotes trustless, fair rewards; needs refinement for broader applicability and security.                 |

# Literature Survey

| Publication Year | Title of Paper                                                 | Abstract                                                                                           | Research Gap                                                           | Conclusion                                                                                         |
|------------------|----------------------------------------------------------------|----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| 2023             | Predicting the Effectiveness of Blockchain Bug Bounty Programs | Analyzes ~200 blockchain bug bounty programs to identify success factors and participation trends. | Missing/uneven data across platforms; limited variables.               | Clear guidelines and documentation improve participation; future work to refine model and dataset. |
| 2019             | An Empirical Study of Bug Bounty Programs                      | Examines economics of traditional bug bounty programs across HackerOne and BugCrowd.               | Limited transparency and productivity data; lacks longitudinal models. | Bug bounties are cost-effective complements to in-house security efforts.                          |



# Literature Survey

## Study of existing systems

| Feature          | Bugcrowd                                    | Immunefi                                         | Hats Finance                                           |
|------------------|---------------------------------------------|--------------------------------------------------|--------------------------------------------------------|
| Type             | Centralized Bug Bounty Platform             | Web3/DeFi Security Bug Bounty Platform           | DAO-based Decentralized Bug Bounty Protocol            |
| Primary Focus    | Traditional web, mobile, and cloud security | Smart contracts, DeFi, blockchain infrastructure | Blockchain security and community-driven bounty vaults |
| Governance Model | Managed by Bugcrowd team                    | Managed by Immunefi team                         | Decentralized via DAO (governance token: HAT)          |
| Report Handling  | Private submission via platform UI          | Private submission; project verifies validity    | Encrypted submission, revealed post-validation by DAO  |
| Verification     | Centralized triage team                     | Security team of the project                     | DAO or committee votes on validity                     |
| Transparency     | Limited (off-chain)                         | Moderate (summary disclosed after fix)           | High (on-chain transparency with report hash)          |

# Methodology Employed

## ❖ **Bounty Creation**

→ Owner drafts bounty with tiers & deadlines, Funds escrow smart contract on **Solana chain**.

## ❖ **Submission**

→ Researcher prepares and encrypts report (client-side).

→ Report stored on **IPFS**; metadata and pointers stored in **PostgreSQL** via backend.

## ❖ **Validation & Triage**

→ Backend (Express + Prisma) validates submission format, Owner reviews securely through auditing service.

## ❖ **Decision & Payout**

→ On acceptance, **Solana contract releases payout** to researcher's wallet.

→ Optional dispute handled via off-chain arbitration + contract hooks.

## ❖ **Settlement & Reputation**

→ Smart contract emits payout event.

→ Backend services update researcher reputation, logs, and notifications.

# Hardware, Software, Tools and constraint

## Hardware :

- x64 machine.
- 8–16 GB RAM
- Minimum 50 GB storage

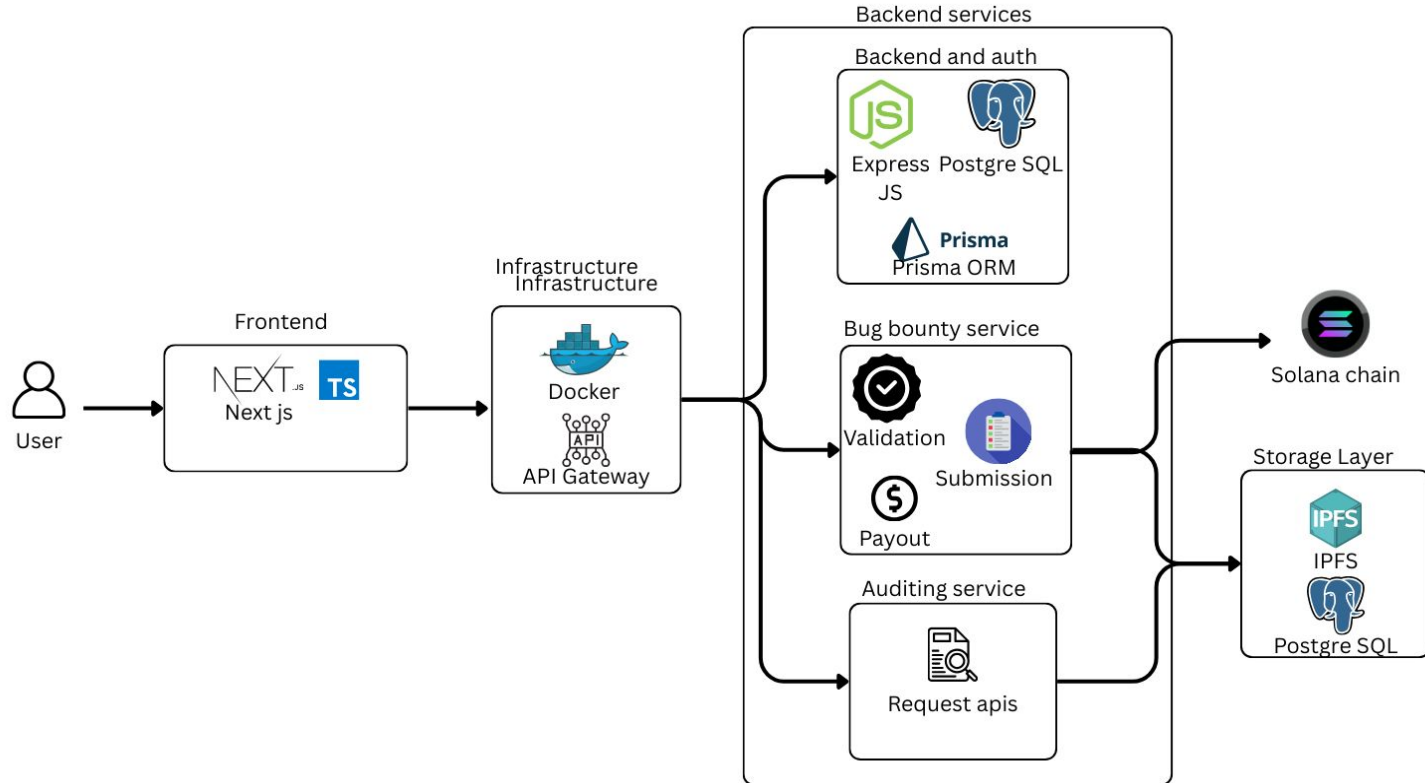
## Tools :

- Visual studio code IDE

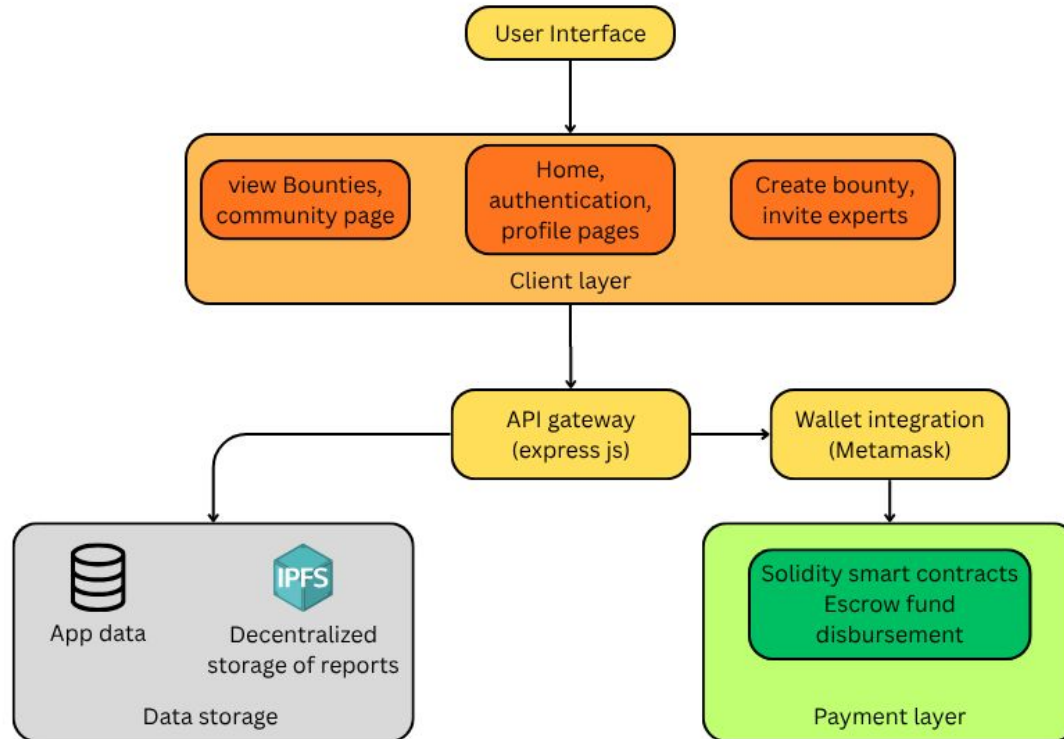
## Tech Stack :

- Frontend: Next.js
- Backend: [Node.js](#), Express, Redis, Typescript
- Blockchain: Solana/Polygon.
- Storage: NeonDb serverless Postgresql, IPFS.
- Identity: Rainbow Kit , JWT , ZK proof
- Infrastructure: Docker
- Monitoring: Prometheus & Grafana
- CI/CD: GitHub Actions, Vercel, Render.

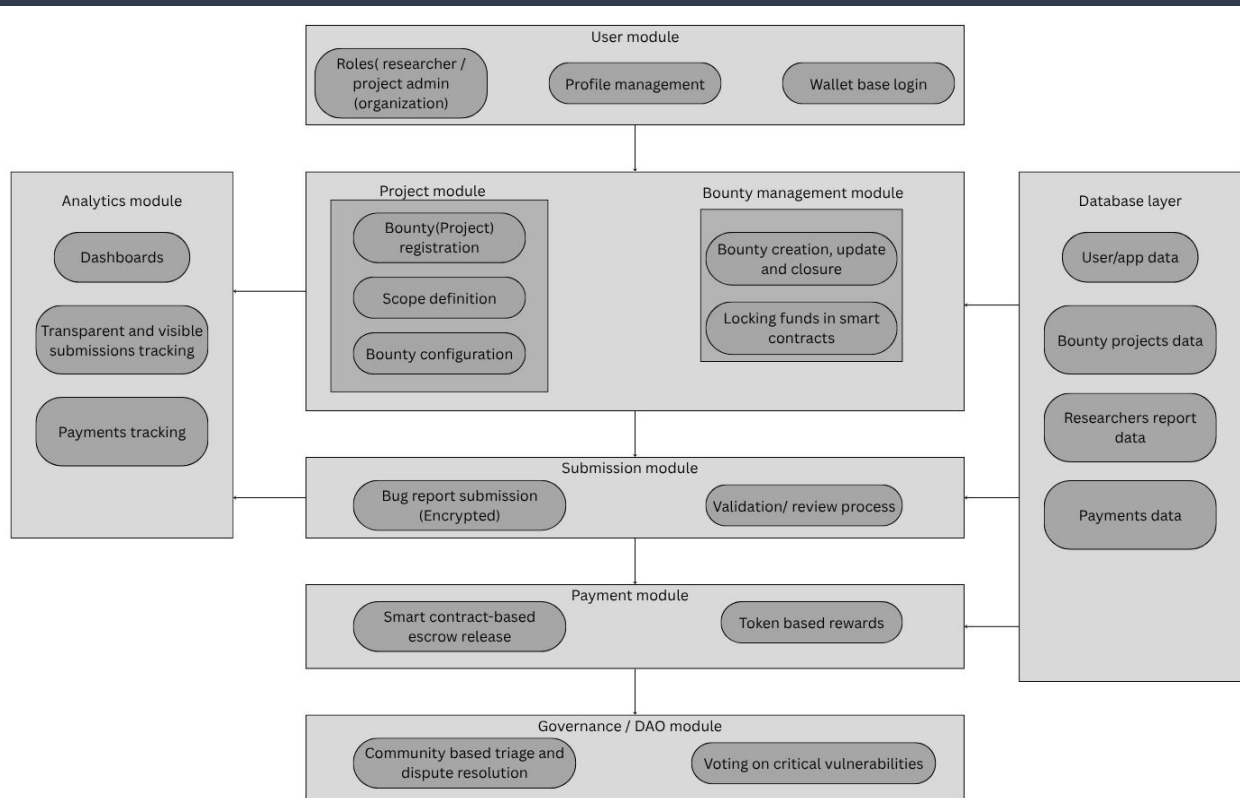
# Block Diagram [\(Link\)](#)



# Block Diagram



# Modular Diagram



# Next Work Plan

- ❖ **Bounty Service** → create, list, update, close bounties (with categories, rewards, deadlines).
- ❖ **Fund Service** → integrate blockchain payments (start with Solana SDK), handle deposits/escrow of bounty funds.
- ❖ **Submission Service** → allow researchers to submit vulnerabilities, attach evidence, track status.
- ❖ **Notifications Service** → real-time updates using **WebSocket** (authenticated with JWT).
- ❖ **Caching & Optimization** → Redis for sessions, caching bounty listings, profile lookups.
- ❖ **Monitoring & Logging** → Prometheus + Grafana for metrics, alerts, dashboards.
- ❖ **Storage Integration** → IPFS for decentralized storage of reports & evidence.
- ❖ **Infra** → Dockerize all services, orchestrate with AWS ECS/Kubernetes.

# Conclusion

DeBug represents a pioneering step toward transforming the traditional bug-bounty landscape through decentralization and trustless collaboration. By combining the transparency and security of blockchain with the efficiency of off-chain services, DeBug ensures verifiable payouts, protects researcher privacy, and streamlines the vulnerability disclosure process. Smart contracts deployed on the Solana blockchain enable automated and tamper-proof escrows, while encrypted submissions and zero-knowledge identity mechanisms maintain researcher anonymity. The integrated reputation system fosters credibility and enables recognition portability across multiple programs. Through this hybrid on-chain/off-chain architecture, DeBug achieves both scalability and cost efficiency, creating a fair, secure, and researcher-friendly ecosystem for responsible vulnerability management. Future enhancements may include multi-chain integration, DAO-based governance, and advanced analytics to further strengthen transparency, accountability, and global participation.



# References

- [1] Outpost24. (2022). What are Bug Bounty Programs? [Link](#)
- [2] Hoffman, E., Grishchenko, I., & Schär, F. (2021). Bountychain: A decentralized bug bounty platform. In International Conference on Blockchain Technology (Springer). [Link](#)
- [3] Coindesk. (2018). Gitcoin and Bounties Network: Blockchain-based freelance and bug bounty markets. [Link](#)
- [4] USENIX Security Symposium. (2018). The Hydra Framework: Incentivizing responsible vulnerability disclosure with smart contracts. [Link](#)
- [5] Lido Research Forum. (2022). Hats.finance: DAO-managed bug bounty vaults. [Link](#)
- [6] Greenberg, A. (2019). Apple vs. exploit brokers: Why capped bug bounties fall short. USENIX/WIRED discussion. [Link](#)
- [7] Stock, B., & Johns, M. (2019). The economics of bug bounty programs and researcher incentives. Journal of Cybersecurity.
- [8] Immunefi. (2021). State of Web3 Bug Bounties. [Link](#)